Technical Proposal

City of Portsmouth Network Audit and Vulnerability Assessment

JLGOV LLC
Joseph Lee, CEO
240.447.3895, j.lee@jlgov.com

4/8/2014

Technical Proposal

Network Audit and Vulnerability Assessment
RFP P129-14-MA

Submitted to
City of Portsmouth
Purchasing Office
801 Crawford Street, 5th Floor
Portsmouth, VA 23704
Atten: Michael Ammons tel 757-393-8858 ext 6148
ammonsm@portsmouthva.gov

Submitted by:

JLGOV LLC

POC: Joseph Lee,CEO 240.447.3895, j.lee@jlgov.com

P.O. Box: 65404 | Virginia Beach, Virginia. 23467
Office: 1-866-781-1822 Fax: 1-866-848-7206

DUNS: 078753898 CAGE: 6UYP2
Certified/Registered: SWaM, Minority Owned, SDB & DBE
NAICS: 541512, 541513, 541519, 541511, 511210

Contents

Executive Summary ***5***

Exhibit: JLGOV's ITIL-based Approach to Providing World-class Service Delivery ***5***

Understanding of Needs ***5***

Exhibit: Multiple Sites Connected via Dedicated Leased Data Circuits and other Connections Makes this Project Challenging ***6***

Our Team ***6***

Our Value Proposition ***6***

Experience ***7***

Qualifications ***7***

History ***7***

Quality ***8***

Exhibit: Lines of Communication and Coordination (organization of project) ***9***

Exhibit: vPMO Portal Provides Stakeholders Secure Access ***10***

Exhibit: Core Security Assessment Strategy ***11***

Phase ***11***

Activity ***11***

Exhibit: The Audit Process ***14***

Gaining Access to Network Resources ***16***

Executive Summary: ***16***

Technical Summary: ***17***

Exhibit: Risk Assessment Overview ***18***

Project Management ***18***

Our Toolset ***19***

Tool ***19***

Summary ***19***

Area of Assessment ***19***

Work Breakdown Structure ***19***

Activity ***19***

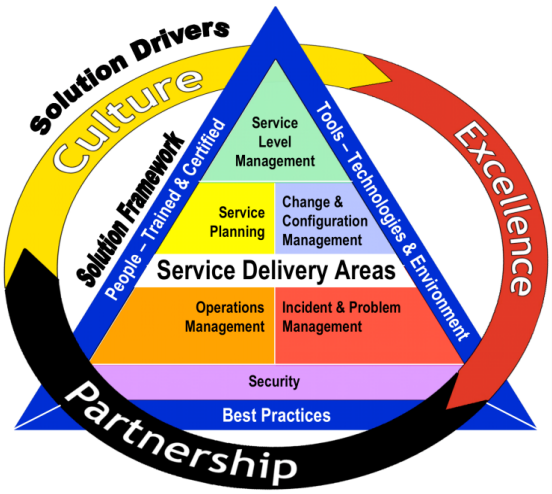
Responsibility ***19***

Duration ***19***

Executive Summary

JLGOV will incorporate its ITIL-based industry best practices to all aspects of this network penetration testing and security assessment project: technical, management, and human resources. Our approach includes the introduction of a systematic framework for delving into an organization's infrastructure using the best practices of world-class companies as defined by the IT Service Management and the ITIL standard, but tailored to the unique processes and intricacies of the City of Portsmouth's environment. Our approach outlines an extensive set of management and technical procedures used by our team members for this effort. JLGOV has developed its own version of these procedures to provide guidance across the breadth of IT infrastructure, development, and operations. We will support the City of Portsmouth in securing its IT operations, with a tried-and-true approach, quality-based practices — to bring true value to your IT operations.

Exhibit: JLGOV's ITIL-based Approach to Providing World-class Service Delivery



Our ITIL-based approach provides a codifying basis to providing security validation and network testing processes, procedures, and activities. Three fundamental drivers have framed the development of our solution:

Culture. We will develop an understanding of and commitment to the culture of your organization ensures our services integrate within that culture.

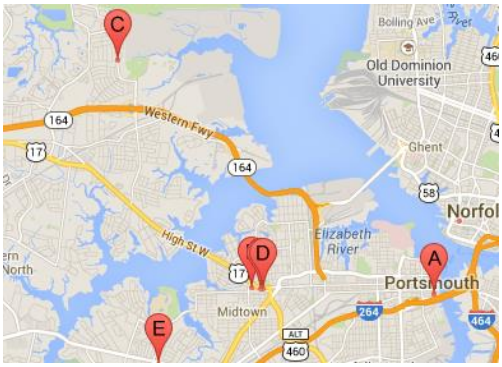
Excellence. A commitment to excellence that is ingrained in all JLGOV projects, and is embodied in our aggressive commitment to service cyber security services to ensure the attainment of project goals.

Partnership. A pledge to work side-by-side with your IT personnel to provide outstanding enterprise service—at reasonable costs—that will apply proven network security analysis processes to the City of Portsmouth infrastructure, satisfy bit management and stakeholders, to enable you to sustain critical operations securely and with confidence.

Understanding of Needs

JLGOV understands the City of Portsmouth has an extensive an complex network of IT systems (computers, routers, servers, and other network infrastructure) located at different sites throughout the city. Devices are networked to the City Data Center and other location with dedicated (leased line) connections, dial-up and wireless media.

Exhibit: Multiple Sites Connected via Dedicated Leased Data Circuits and other Connections Makes this Project Challenging



City employees access the networked computing resources to enable their work; the Department of Information Technology administers the network. JLGOV understands we will support the Department in evaluating the vulnerability of the network to unauthorized access (by authorized users straying into restricted areas, and by unauthorized external sources). We understand we will provide effective security recommendations to eliminate potential problem areas, so the Department and City of Portsmouth can implement best practices in security management.

Our Team

JLGOV's security assessment team is headed by Hallet Chatman, who has over fifteen years of leading projects as a team lead and instructor experience (résumé in the annex for details). He is supported by Senior Security Engineers and other technologists from JLGOV's stable of experienced personnel. Mr. Chatman will be dedicated at a 100% level of effort (LOE) for the duration of this project, on-site as required. Further, the team has the full support and access to company resources — which we refer to as "corporate reach-back" — so that the team may draw upon the financial and technology resources of the firm during execution, as well as access to our President, Joseph Lee, and other subject matter experts who may be called upon as needed.

Our Value Proposition

JLGOV will conduct vulnerability and penetration assessments from within the customer network and external to it. An internal assessment will expose vulnerabilities that employees, contractors, or any other third parties may exploit. An external assessment provides a view of the security liabilities as seen by citizens, customers, other end users, and, of course, black-hat hackers. Our advice therefore is to improve the client's security processes upon completing of an assessment. A solid Security Awareness Program will not only increase the City of Portsmouth's overall security posture, but end users and other stakeholders will be happier because

By retaining JLGOV, the City of Portsmouth can be confident we will work on-site to identify your current security posture and goals, then measure the effectiveness of existing infrastructure and process, identify the gaps, and recommend a remediation plan.

Overview of Company

JLGOV's philosophy can be summed up as: we strive to be a primary source for security assessment and other technology services for our clients. The foundation of our business starts with those professionals dedicated and passionate to go the extra mile for our customers. Diversity is viewed as an essential component of our culture. If our employees are satisfied, then our clients will be satisfied. We see communication as the key to integrity, which promotes trust and leads to success for our clients. We are a solution looking for a problem to solve and predicting to complete project ahead of schedule

Experience

Our project manager is well established has lead major project efforts across government and healthcare verticals. Project Lead responsible for ensuring project is completed, on time, and within budget. He is an expert in scheduling, meeting deadlines and seasoned technical Writer/Analyst with the ability to document in curriculum all types of Software, Engineering, Computer Systems, and Information Technology processes. His efforts has spanned developing governance policy, business rules, and site manager training plans. Mr. Chatman was also responsible for creating, editing, and writing a Pamphlet that will used by the Defense Contract Management Agency (DCMA) to help provide guidelines that the government can use to ensure Federal Acquisition Programs, supplies, and services are delivered on time, within cost, and meet performance requirements. Update and Manage a CMMI compliant training database by creating tables, running queries, & verifying all data inputs with respect to Role Required Training and participated in CMMI Level 4 & 5 appraisals for the Systems Engineering and Software groups.

Our Project Manager will serve as the main Point of Contact (POC) who will support the project deliverables and schedule. Our Project Manager will liaise with the City Of Portsmouth IT Director and Team Lead(s) regarding issues to be addressed under this project. He will allocate the appropriate JLGOV Team staff to prepare for work assignments and address issues. It is important that the City of Portsmouth management personnel be responsible for executing the project, be dedicated and involved in developing the work plan, staffing, schedule of activities/deliverables, and budget.

Timely completion and high-quality performance are the products of thorough planning before the work on the project begins. Our Team employs a variety of systems and corporate management tools to support project planning and management. The JLGOV Team approach to project management clearly defines and controls schedules and deliverables, processes, and procedures for reporting data and staffing with qualified personnel.

Qualifications

The firm supports the Project Manager with a team of talented technologists, systems engineers, and business analysts. This “corporate reach-back” ensures the City of Portsmouth has access to a qualified team to implement the security vulnerability assessment and audit activities of this project. All JLGOV team member who are involved in assessing security for the company's clients must undergo and pass the our internal training course — this qualifies individual employees, through training and testing, to perform the assessments. Besides internal qualification, our Security Engineers has completed Systems Security Professional (CISSP), Certified Ethical Hacker (CEH), EC Council Certified Hacking Forensics Investigator (CHFI), ISO/IEC 27002 and ITILv3 certifications in this area.

History

JLGOV’s management team has over 14 years of experience in the information technology arena from consulting, engineering and sales across multiple verticals. JLGOV obtained the following certifications as a small business entity; SWaM, SDB, MBE, Minority owned and DBE certifications. The company is a primary source for business process outsourcing, network security consulting, staff augmentation, and technology and cloud services for its clients.

JLGOV is very familiar with the National Cyber Security Division (NCSD) of the U.S. Department of Homeland Security. This organization’s mission is to work collaboratively with public, private, and international entities to secure cyberspace and America’s cyber assets. Further, we have

worked on several projects where the client organization must comply with the HIPAA security rule, 45 CFR parts 160, 162 and 164. The HIPAA security framework calls for due diligence based on good business practices, for systems handling electronic protected health information (EPHI). Creating an Information Risk Assessment Report (see the WBS, following) satisfies the rule's requirements to analyze risks, formulate appropriate safeguards, and document the risk management decision-making process (45 CFR part 164.308(a)(1)(ii)(A)(B)) and informs an organization's actions in complying with other parts of the rule.

The Federal Information Security Management Act (FISMA) was developed in 2002 as recognition by the federal government for the need of organizations to develop an information security program to protect assets and preserve economic and national security interests. JLGOV understands that the FISMA process draws from a variety of standards and frameworks including NIST and FIPS, having participated and, in some cases, led FISMA compliance audits.

Quality

The JLGOV Team operates according to established corporate policies and procedures enforced by Executive Management. Our Quality Assurance Plan (QAP) dictates contract administration to control costs and ensure the delivery of quality work products under Total Quality Management standards. We use an automated management information system (see the vPMO section, following) to manage information that allows program and project managers to define workload indices, track expenditures, plan deliverables, and identify labor requirements. Our management concepts for providing quality products and services include:

Establish quantifiable goals and objectives for each task/subtask;

- Defining workload indices for all assignments, to include: inputs and outputs by item type, due dates/times, days/time-to-complete, labor hours per task/subtask, consumable (costs) per tasks/subtask, and travel (cost) per task/subtask;
- Integrating management and technical expertise across client requirements to achieve in-depth results and world-class quality;
- Planning resource allocations, by indices, for tasks/subtasks on annual, quarterly, monthly, and weekly basis;
- Tracking actual expenditures associated with allocation;
- Performing frequent (weekly) variance analysis of planned-vs-actual contract resources and costs; and
- Determining needed adjustments to any over-utilization or under-utilization of labor materials based on variance analysis.

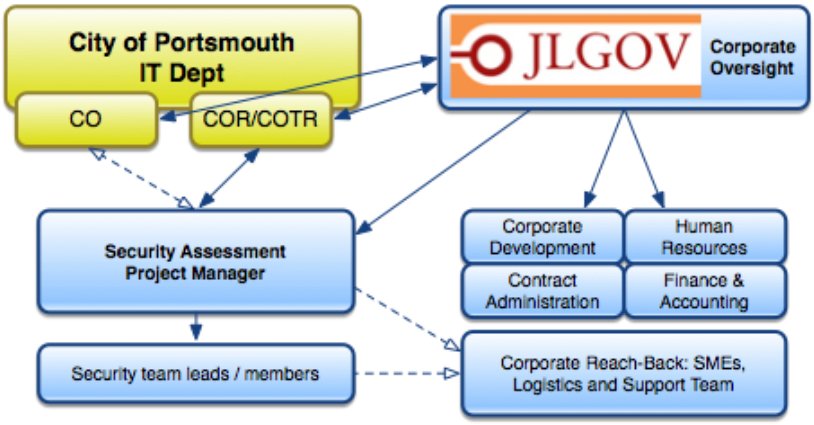
Methodology

JLGOV offers a management and technical team ready to support City from kick-off. Our management approach ensures that we will be successful by providing the proven processes, reliable leadership, and qualified staff City wants and requires. JLGOV's project management approach will be implement in compliance with JLGOV's policies and procedures, tailored to respond to the Department of Information Technology's requirements. The management approach will be executed by our Project Manager (PM). Our Project Management Body of Knowledge (PMBOK)–aligned project management process includes risk management, quality assurance (QA), reporting, subcontract management, and communications strategies to ensure

delivery of high quality, low-risk IT infrastructure security assessment services. JLGOV will perform the activities outlined in the Work Breakdown Structure (WBS) in adherence with City of Portsmouth directives and policies.

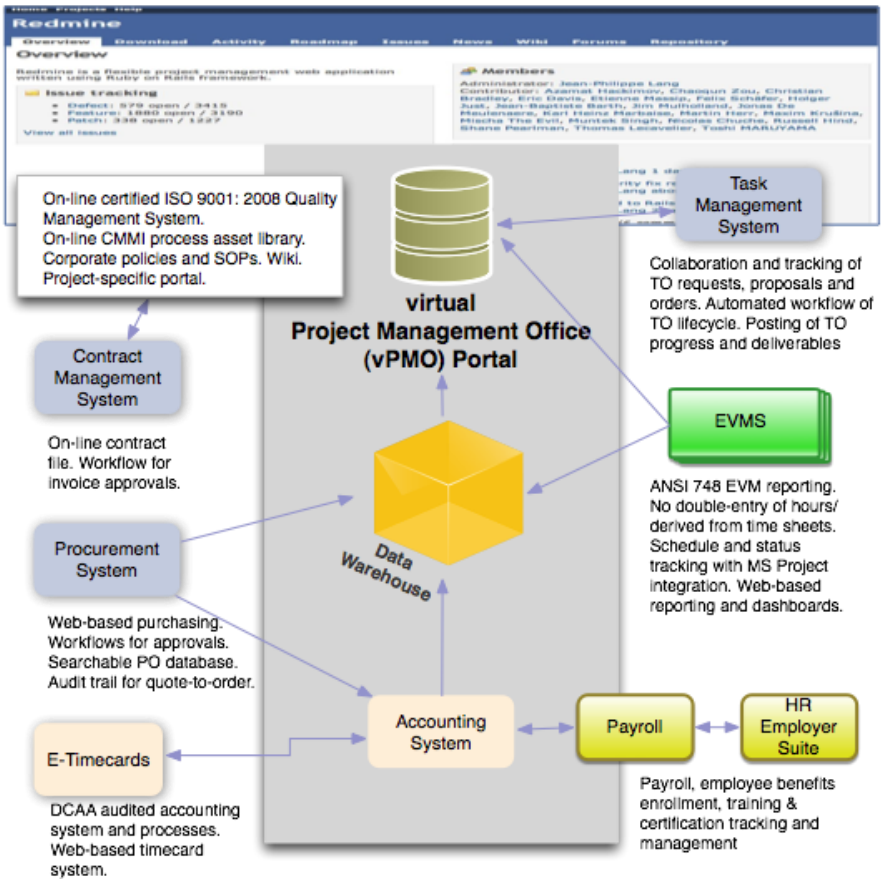
Lines of Communication. This project is led by our experience PM, who will be the single point of contact for the City of Portsmouth technical liaison.

Exhibit: Lines of Communication and Coordination (organization of project)



Virtual Project Management Office. Over the last decade, JLGOV management has come to understand the need for various types of information systems to support the many activities needed to carry out clients' projects. Each of these information systems has a particular purpose or focus, and each has a life cycle of its own. We are confident that we can successfully manage the City of Portsmouth's defined needs, following a timeline and work plan (based on the draft in this proposal) that will be agreed after coordination with client stakeholders at kick-off. More specifically, we are confident that we will ensure that the expertise and resources of our project staff, organizational stakeholders, and relevant personnel can be effectively coordinated and focused to achieve all of the project's goals. In addition to the reports required in the RFP, we will provide both weekly activity reports and a final project report, through our Virtual Project Management Office (vPMO) portal. JLGOV utilizes our vPMO portal to help oversee tasks, personnel management, and deal with issue response. This vPMO portal works with Microsoft Project and SharePoint, which will benefit this effort for project status reporting. This portal provides visibility into task status, issues, risks, and project artifacts.

Exhibit: vPMO Portal Provides Stakeholders Secure Access



This is provided at no cost to the customer and has been used consistently on other government and commercial engagements. The data presented via the dashboard is managed by our PM who monitors resources and spend plans, as well as aggregating project schedule, technical, and reporting data.

Our team's PM will provide a Weekly Activity Report (WAR) to the customer via e-mail identifying progress on this effort, completed tasks, upcoming ones, and any new, resolved or open issues. The WAR shows all work scheduled to be performed the upcoming week, to include all scheduled training, security assessment activities, situations requiring interaction with City of Portsmouth personnel, meetings (face-to-face or virtual), and reports. The WAR also shows deliverables due, in-progress, or other schedule details. All WARs will roll-up into the final project status report at the conclusion of this effort. All reports will be archived in the portal for secure access.

Security of Customer Information.

JLGOV's staff will comply with all applicable IT systems security and privacy specifications as required by the customer, as directed by the organization's security personnel — JLGOV's PM, will be the JLGOV representative responsible for all technical information security activities, including ensuring that all of our team complete any client security training commensurate with their responsibilities. The objectives of JLGOV's team preparation are as follows:

- Acquaint Project Team with the security procedures required to ensure protection of personal and other confidential data.
- Clarify JLGOV employee responsibilities and duties with respect to the protection of appropriate protected information.
- Enable task managers to make decisions about information security which are in keeping with standard policies and procedures, and which are responsive to prevailing local conditions.
- Coordinate the efforts of different team members supporting the City of Portsmouth so that information resources are properly and consistently protected, regardless of their location, form, or supporting technologies.

- Provide guidance for the performance of information system security audits and reviews.
- Demonstrate management support for a strong information security plan.
- Establish a basis for disciplinary actions when required to address any violations.
- The team will take the appropriate steps to ensure City of Portsmouth information systems are properly protected during our audit. Two key concepts form the backbone of JLGOV's security program:
- All information access is granted on a “need to know” basis only.
- Information security is the responsibility of the individual employee.

JLGOV will ensure that all necessary administrative, physical, and technical safeguards will be employed to systems that collect, use, maintain, or disseminate personally identifiable information or other information designated as sensitive.

In most organizations, the firewall represents the first line of defense to outside threats. The City of Portsmouth may have also enable firewall capabilities at the edge the network, in the internet router(s). Behind the firewall and before the corporate network resides the DMZ, the hardened and semi-trusted zone of the City’s network that is used to house the web servers, e-mail and other internet services. Beyond the DMZ, separated by another firewall, resides the most secure portion of the network, where end users and enterprise services co-exist.

JLGOV’s key to the success of a network security and vulnerability project is to establish a flexible core strategy which is adapted and customized to suit the project’s needs for that stage. Our approach consists of: planning, preparing, performing and reporting, as shown in the following exhibit. Details of implementing this strategy to conduct stage reviews for City of Portsmouth network (internal and external) and enterprise systems is shown the following exhibit. JLGOV’s hybrid approach is based on E911 and Supervisory Control and Data Acquisition (SCADA) penetration testing methodologies.

Exhibit: Core Security Assessment Strategy

Phase	Activity
External Network Penetration Testing	The core ideal around JLGOV’s “Blackbox” Network Penetration Testing methodology is to organize and to iteratively test the target environment from the most general components to the most specific. In this way we can effectively model attack scenarios that highlight risk from the largest, most complex environments down to the most simple, and anywhere in between. The entire testing process is primarily manual to limit generic results from scanners and checklist methods used in general vulnerability assessments. In this way we can focus the engagement on directed attack logic based testing against systems and networks.

Phase	Activity
Internal Network Penetration Testing	Our internal network penetration testing ("Whitebox") assesses security through the eye of an internal user, a temporary worker, or an individual that has physical access to the organization's buildings. Internal Penetration Tests are conducted from within an organization, over its Local Area Network (LAN) or through WIFI networks. The tests will observe whether it is possible to gain access to privileged company information from systems that are inside the corporate firewalls. Testers will assess the environment without credentials, and determine whether a user with physical access to the environment could extract credentials and then escalate privileges to that of an administrator or super user within the environment. During an Internal Penetration Test, the tester will attempt to gain access to sensitive data. They will also assess whether it is possible to extract data from the corporate environment and bypass the security. Our security testing specialists will work with you to design the most effective testing scenario.
Vulnerability Assessment	Vulnerability Assessment by JLGOV consists of a series of automated scripts and checks to assess an infrastructure against known exposures. Automated tests can be completed very quickly and are the cheapest form of test to conduct. However, they also lack human logic and are consequently not able to assess an infrastructure as thoroughly as a consultancy led assessment
Reporting and Documentation	JLGOV produces a high level management report and an in-depth technical review document for each engagement. These documents will highlight security vulnerabilities and identify areas for exploitation. In addition, they will provide guidance on remediation, with a focus on preventative countermeasures.

The methodology above consists of the following:

- **Reconnaissance**. Identification of all system, data, and network components that fall within scope of the penetration test.
- **Enumeration**. Determination of application and network level services in operation for all identified assets. This includes a port scan of all 65,536 (including port 0) TCP and UDP ports of assets that fall within scope.
- **Vulnerability Scanning**. Determination of the vulnerabilities, bugs and configuration concerns with all systems. Flaws identified in any of these three areas can lead to system compromise.

- **Exploitation**. For each issue or concern identified above, we escalate, validate and then determine the impact of these on your network. This is used to develop findings along with impact descriptions and recommendations that take into account your individual business and network environment. i.e. throw away the false positives and create an actionable penetration testing report.
- **Patching**. Once vulnerabilities have been identified, we will look for advisories to recommend to patch the vulnerable software services.
- **Reporting**. Findings are consolidated into a professional report that can be provided for audit purposes or distributed internally to remediate issues.

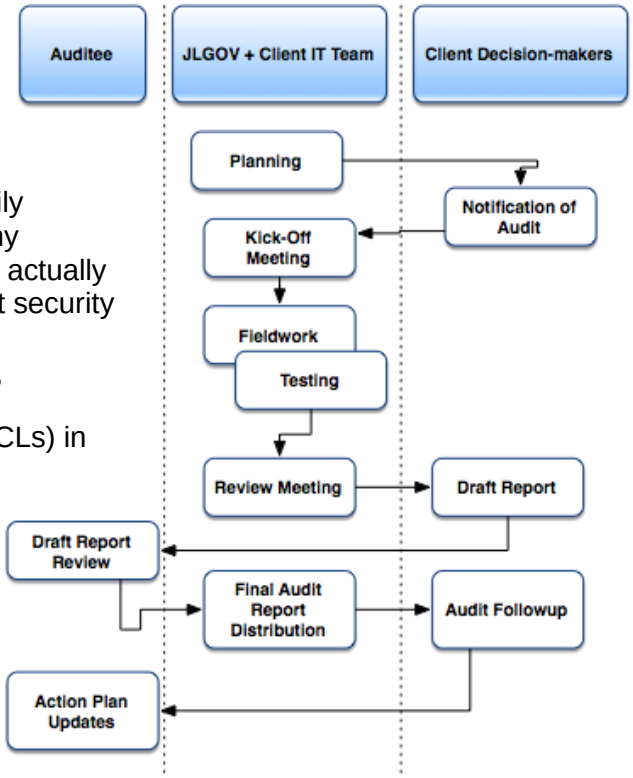
Audit Process

In addition to the penetration testing — which is a very narrowly focused attempt to look for security holes in a critical resource, such as a firewall or Web server — we will audit security processes. Penetration testers will only be looking at limited services on a network resource, and will operate from both outside and inside the firewall with minimal information in order to more realistically simulate the means by which a hacker would attack the site.

JLGOV's computer security audit is a systematic, measurable technical assessment of how the organization's security policy is employed at a specific site. Computer security auditors work with the full knowledge of the organization, at times with considerable inside information, in order to understand the resources to be audited.

Security audits do not take place in a stand-alone manner; they are part of the on-going process of defining and maintaining effective security policies. It involves everyone who uses any computer resources throughout the City. Given the dynamic nature of computer configurations and information storage, some may wonder if there is truly any way to check the security ledgers, so to speak. Security audits provide such a tool, a fair and measurable way to examine how secure a site really is.

Exhibit: The Audit Process



Our computer security auditors perform their work though personal interviews, vulnerability scans, examination of operating system settings, analyses of network shares, and historical data. They are concerned primarily with how security policies - the foundation of any effective organizational security strategy — are actually used. There are a number of key questions that security audits should attempt to answer:

- Are passwords difficult to crack?
- Are there access control lists (ACLs) in place on network devices to control who has access to shared data?
- Are there audit logs to record who accesses data?
- Are the audit logs reviewed?
- Are the security settings for operating systems in accordance with accepted industry security practices?
- Have all unnecessary applications and computer services been eliminated for each system?
- Are these operating systems and commercial applications patched to current levels?
- How is backup media stored? Who has access to it? Is it up-to-date?
- Is there a disaster recovery plan? Have the participants and stakeholders ever rehearsed the disaster recovery plan?
- Are there adequate cryptographic tools in place to govern data encryption, and have these tools been properly configured?
- Have custom-built applications been written with security in mind?
- How have these custom applications been tested for security flaws?
- How are configuration and code changes documented at every level? How are these records reviewed and who conducts the review?

Before the computer security auditors even begin an organizational audit, there's a fair amount of homework that should be done. Auditors need to know what they're auditing. In addition to reviewing the results of any previous audits that may have been conducted, there may be several tools they will use or refer to before. The first is a site survey. This is a technical description of the system's hosts. It also includes management and user demographics. This information may be out of date, but it can still provide a general framework. Security questionnaires may be used as to follow up the site survey. These questionnaires are, by nature, subjective measurements, but they are useful because they provide a framework of agreed-upon security practices. The respondents are usually asked to rate the controls used to govern access to IT assets. These controls include: management controls,

authentication/access controls, physical security, outsider access to systems, system administration controls and procedures, connections to external networks, remote access, incident response, and contingency planning.

Site surveys and security questionnaires should be clearly written with quantifiable responses of specific requirements. They should offer a numerical scale from least desired (does not meet requirements) to most desired (meets requirements and has supporting documentation). Both should include electronic commerce considerations if appropriate to the client organization. For instance, credit card companies have compliance templates listing specific security considerations for their products. These measure network, operating system, and application security as well as physical security.

Auditors should review previous security incidents at the client organization to gain an idea of historical weak points in the organization's security profile. It should also examine current conditions to ensure that repeat incidents cannot occur. If auditors are asked to examine a system that allows Internet connections, they may also want to know about IDS/Firewall log trends. Do these logs show any trends in attempts to exploit weaknesses? Could there be an underlying reason (such as faulty firewall rules) that such attempts are taking place on an ongoing basis. How can this be tested?

Because of the breadth of data to be examined, auditors will want to work with the client to determine the scope of the audit. Factors to consider include: the site business plan, the type of data being protected and the value/importance of that data to the client organization, previous security incidents, the time available to complete the audit and the talent/expertise of the auditors. Good auditors will want to have the scope of the audit clearly defined, understood and agreed to by the client.

Next, the auditors will develop audit plan. This plan will cover how will audit be executed, with which personnel, and using what tools. They will then discuss the plan with the requesting agency. Next they discuss the objective of the audit with site personnel along with some of the logistical details, such as the time of the audit, which site staff may be involved and how the audit will affect daily operations. Next, the auditors should ensure audit objectives are understood.

When the auditors arrive at the site, their aim is to not to adversely affect business transactions during the audit. They should conduct an entry briefing where they again outline the scope of the audit and what they are going to accomplish. Any questions that site management may have should be addressed and last minute requests considered within the framework of the original audit proposal.

After the audit is complete, the auditors will conduct an outgoing briefing, ensuring that management is aware of any problems that need immediate correction. Questions from management are answered in a general manner so as not to create a false impression of the audit's outcome. It should be stressed that the auditors may not be in a position to provide definitive answers at this point in time. Any final answers will be provided following the final analysis of the audit results.

Once back in the home office, the auditors will begin to comb their checklists and analyze data discovered through vulnerability assessment tools. There should be an initial meeting to help focus the outcome of the audit results. During this meeting, the auditors can identify problem areas and possible solutions. The audit report can be prepared in a number of formats, but auditors should keep the report simple and direct, containing concrete findings with measurable ways to correct the discovered deficiencies.

The audit report can follow a general format of executive summary, detailed findings and supporting data, such as scan reports as report appendices. When you write the report, develop executive summary first, as you may have to brief management soon after return. It's important to realize that strengths as well as deficiencies can be addressed in the executive summary to help give an overall balance to the audit report. Next, the auditors can provide detailed report based on audit checklists. The audit findings should be organized in a simple and logical manner on one-page worksheets for each discovered problem. This worksheet outlines the problem, its implications, and how it can be corrected. Space should be left on the worksheet to allow the site to document corrective steps and a comment block to dispute the finding if appropriate.

We suggest, that as organizations evolve, their security structures change as well. The computer security audit is not a one-time task, but a continual effort to improve data protection. The audit measures the organization's security policy and provides an analysis of the effectiveness of that policy within the context of the organization's structure, objectives and activities.

Gaining Access to Network Resources

Through the use of automated vulnerability assessment tools, JLGOV will analyze the network devices to pinpoint weaknesses that could lead to system compromise. In addition, JLGOV employs manual techniques to deep dive on critical network devices and to focus on vulnerabilities not identified by the automated scanning tools. JLGOV validates the vulnerabilities to eliminate false positives that may be reported by the vulnerability scanning tools. The vulnerability scans are scheduled and configured to minimize the impact on the target network. This assessment is used to identify potential vulnerabilities in the network to guide the system administrators in the remediation process to mitigate the risk of network and data compromise.

These testing procedures will be performed “blind”, meaning the security professional is not provided information about the network; and, under other tasking, “open”, meaning the security professional is provided information such as network diagrams, IP addresses and server lists to guide the approach taken by our security professional. By using both types of assessment, JLGOV will be able to provide a complete picture to the City regarding the effectiveness of the security controls being tested as part of the project.

In order to replicate a real-world attack by an unauthorized user, JLGOV utilizes the information gathered during the vulnerability assessment phase to attempt to gain access to the network. The JLGOV security professional employs manual techniques to exploit vulnerabilities in the environment due to un-patched or misconfigured systems.

The penetration test provides the City of Portsmouth with an understanding of the exploitable threats in the environment. It also could also be used to test the incident and threat identification and response plan of your security department.

Providing the City with actionable information is the goal of this network assessment services. From the information gathered during the vulnerability assessment and penetration testing we will prepare a security assessment report including the following sections:

Executive Summary:

JLGOV's understanding of technology and business processes allows us to create a report that translates the technical vulnerabilities identified during the engagement in to the risks they present to the business. The executive summary is a snapshot of all of the technical data into actionable, risk based recommendations for management to analyze.

Technical Summary:

Vulnerability scanners and assessment techniques identify real issues with the environment as well as false positives. JLGOV's security professionals analyze the information gathered during the engagement and remove the false positives to present a clear picture of the issues in the environment. We also analyze the risk caused by the vulnerabilities based on our understanding of your environment and provide a risk ranking, independent of that assigned by the scanning tools. The technical summary provided by us will include the real threats to your environment, including screen shots and test results, with recommendations on how to address them.

A sample security assessment report is provided as an annex.

In addition, we will evaluate enterprise applications' public facing interfaces. JLGOV believes software assurance is critical because software is the core constituent of modern products and services – it enables functionality and business operations. And software provides a high level of mission risk due to increasing dependence and system interdependence (where the weakest link can often be found). Our experts have found that software size and complexity obscures intent and precludes exhaustive test. The City may find, as a result of JLGOV's efforts, that outsourcing and use of an un-vetted software supply chain opens the door to sophisticated attacks. There are a growing number of vulnerabilities and incidents with threats targeting software. The risk of asymmetric attack means software and the processes for acquiring and developing software represent a material weakness — one an assessment by JLGOV will uncover.

Risk Assessment Guidelines

JLGOV's risk assessment methodology is based on the Centers for Medicare and Medicaid Services (CMS) Information Security Risk Assessment Methodology, developed by the U.S. Department of Health and Human Services, in three phases:

- System Documentation Phase
- Risk Determination Phase
- Safeguard Determination PhaseWe will produce a risk assessment report that:
- Summarizes the system architecture and components, and its overall level of security;

Includes a list of threats and vulnerabilities, the system's current security controls, and its risk levels;

- Recommends safeguards, and describes the expected level of risk that would remain if these safeguards were put in place;
- Shows where an organization needs to concentrate its remedial work and can be used as input to the agency's business continuity plan;
- Presents these findings to stakeholders and City managers.

JLGOV will provide a risk assessment based on our security audit, so that the City may implement a strong response to the gaps we may find. Part of the assessment will include capturing the IT Department staff's knowledge and understanding. Remediation will include quick hit action items, a plan for tracking future risks, and a focus on IT staff knowledge transfer. Lastly, our mitigation plan will tie performance to policy compliance to help ensure fixes get

made — but we caution that the City should be mindful of potential gaps that are outside the control of City staff.

Exhibit: Risk Assessment Overview

Our deliverable, the risk assessment report (see WBS, following), will apply to a selected information system — a group of computing and network components that share a business function, under common ownership and management. The report will address:

A documented system inventory, listing all system components and establishing the system boundary for the purposes of the report;

Documentation of systems' policies and procedures, and details of its operation;

List of threat / vulnerability pairs, with severity of impact and likelihood of occurrence;

List of safeguards for controlling these threats and vulnerabilities and recommended changes, with approximate levels of effort for each;

For each recommended change, the resulting reduction in risk;

The level of residual risk that would remain after the recommended changes are implemented.

The report will reflect the security policies and objectives of the City's information technology management. It will be presented in a face-to-face meeting with the system business and technical owners, the risk assessment manager, and other project team members.

Technical Approach

While external threats receive significant media scrutiny, internal threats remain more common and more costly. JLGOV's approach is to illustrate how can the City can be sure it is up to date on platform, OS and other patches. We understand the City's IT staff is often overburdened, and although they are very competent, JLGOV knows information security issues move fast. Software vendors issue new patches and updates on a weekly, if not daily basis, and new software is installed with default settings that are very weak from a security standpoint. JLGOV's approach for internal threats is to lay out how to harden these devices for security.

Sometimes referred to as internal penetration testing, our internal vulnerability assessment is designed to assess the City's network security posture from the inside. Our information security technicians are experts in the latest networking and operating systems. From Windows to the latest flavors of Linux and OSX, from Citrix to VPNs, our security technicians have the expertise to tell the Department of Information Technology how to harden the City's network for all internal and Internet-exposed platforms.

Project Management

Concerning project management, (WBS 4.0) we will provide our PM and/or backup PM or other appropriate team member to attend weekly meetings. With regard to project planning, we will update our baseline Project Management Plan (the PMP deliverable for WBS activity 4.0) within five days of the kick-off meeting. Ongoing, we will create progress reports (WARs) and make updates to our vPMO portal.

Our Toolset

JLGOV employs a host of technologies to augment the methodology presented. These tools are indispensable in conducting a thorough and timely assessment of IT infrastructure.

Tool	Summary	Area of Assessment
Nessus	A proprietary comprehensive vulnerability scanner which is developed by Tenable. It uses the Common Vulnerabilities and Exposures architecture for easy cross-linking between compliant security tools.	Throughout the exercise
OpenVAS	Used in addition to Nessus (OpenVAS is the OSS version of Tenable COTS product) to provide additional information.	As an adjunct to other tools throughout the exercise
Ethereal/Wireshark	Critical for all penetration testing, we would be using it during almost all phases of the exercise.	All phases of the exercise
Aspect Security AspectCheck	A Bytecode analysis tool	Code review to check for security-critical calls
Boomerang	A decompiler for reverse engineering. Identifies undefined code constructs or run-time errors, such as out-of-bounds array indexing or arithmetic overflow	As an adjunct to other tools throughout the exercise

Work Breakdown Structure

JLGOV provides a Work Breakdown Structure (WBS) as part of our PMP to articulate the decomposition of all the work necessary to complete this project. The WBS is arranged in a hierarchy and constructed to allow for clear and logical groupings, by activities and deliverables.

ID	Activity	Responsibility	Duration
1.0	Perimeter (internet-facing) Network Assessment	Senior Security Engineers	45 days

ID	Activity	Responsibility	Duration
	We will inventory and map all network systems prior to the assessment. The audit will be both remote and onsite breach assessments. We will evaluate security controls to detect and/or prevent unauthorized access to the City's computer networks through its internet connection. Evaluation will include penetration testing of the City web server and other host platforms (database, application, file, backup, etc.) in the data center and other city locations. We will perform network penetration testing designed to test internal systems and applications for potential areas of breach. We will provide a vulnerability assessment to identify potential security concerns throughout the City's IT environment. We will provide a breach assessment by testing as a simulated attacker, evading the City's intrusion detection methods and using a variety of covert attach mechanism, as a real attacker could utilize. We will identify open source intelligence information about the City in a public information profile. This information is something an attacker could leverage in further attacks against the City — email addresses, phone numbers, internal corporate information, posted application source code, forum or social media posts with sensitive information, etc. We will evaluate the security controls employed to detect and/or prevent unauthorized access to the City's network via its VPN. We will evaluate the security controls employed to detect and/or prevent unauthorized access to the City's network via its email system (including access through the web mail interface). We will evaluate the security controls employed to detect and/or prevent unauthorized access to the City's network via its networked mobile data terminals, as found in police vehicles. This type of testing assesses an organizations infrastructure from outside of the perimeter firewall on the Internet. It assesses the environment from the vantage point of an Internet Hacker, a competitor or a supplier with limited information about the Internet facing environment. Perimeter Penetration Testing will assess the security controls configured on the access routers, firewalls, Intrusion Detection Systems (IDS) and Web Application Firewalls (WAFS) that protect the perimeter. External Tests will also provide the ability to assess security controls for applications that are front-facing.		
	Deliverables: (a) Network Asset Inventory; (b) Public Information Profile Report; (c) Vulnerability Assessment Report draft and final.		
2.0	Internal Network Assessment	Senior Security Engineers	45 days

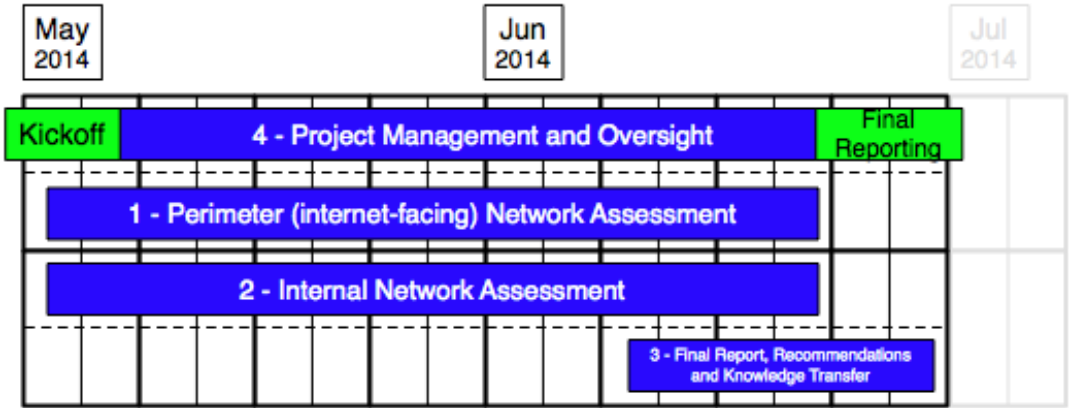
ID	Activity	Responsibility	Duration
	The internal network assessment looks at penetration to address security posture relative to two primary scenarios: an external intruder breaches perimeter defenses, or a malicious insider attempts to access or damage sensitive information or IT resources. We will provide a vulnerability assessment to identify potential security concerns throughout the City IT environment. JLGOV will provide a breach assessment, performing testing as a simulated attacker, evading intrusion detection systems using a variety of covert attack mechanisms, simulating what an attacker could use. Designed to test internal systems and applications, we will perform internal network penetration testing. JLGOV will provide onsite social engineering actions such as employee impersonation, phishing, and phone-based social engineering attacks. We will undertake physical breach attacks at a minimum of five (5) locations. JLGOV will evaluate security controls at City of Portsmouth libraries from the point of access by patrons to detect and/or prevent unauthorized access to the City computer network. JLGOV will evaluate security controls within City of Portsmouth the Circuit Court Clerk's Office from the point of access by patrons to detect and/or prevent unauthorized access to the City computer network. We will assess security controls at up to five (5) point of sale (POS) or self-checkout systems within the City network. We will evaluate security controls within and outside Behavior Healthcare Services to detect and/or prevent unauthorized access to and verify control of HIPAA compliance for personal data. We will assess security controls within the City to detect and/or prevent unauthorized access to the Computer Aided Dispatching System and other 911 systems. We will assess security controls to detect and/or prevent unauthorized access to the systems related to the Portsmouth Water Treatment Plant. We will assess security controls to detect and/or prevent unauthorized access to the systems related to the City's wireless data network — including "password/traffic sniffing" from multiple locations around the City. We will assess security controls to detect and/or prevent unauthorized access to the systems related to the network resources accessed by city employees. This testing will at a minimum include access to sensitive data within City databases, files, and other IT assets Also, from a minimum of 20 locations on the WAN and 10 on various LANS, JLGOV will evaluate existing internal security controls. We will work with the City IT Security Team to identify specific locations to test, as well as locations we will select at random. Post-implementation of recommended security improvements, JLGOV will perform vulnerability testing, and submit our findings in a written report at completion of the second test.		

ID	Activity	Responsibility	Duration
	Deliverables: (a) Comprehensive Report of All Security Findings (summary) with Recommended Corrective Actions and Intrusion Vulnerability Mitigation; Breach Assessment Report; Network Penetration Test Report; (b) Social Engineering Attack Report; (c) Public Building Security Assessment (Libraries, Courts); (d) POS Evaluation Report; (e) HIPAA Compliance Report; (f) Network Security Best Practices White Paper (with recommended technology enhancements, policies and governance model reflecting practical solutions); (g) Post-Mitigation Followup Vulnerability Test Report; (h) Risk Assessment Report.		
3.0	Final Report, Recommendations and Knowledge Transfer	PM, supported by Technical Team	10 days
	Final report on network assessment, security vulnerability assessment and security vulnerability mitigation recommendations. Security management best practices knowledge transfer session(s).		
	Deliverables: (a) Final Report Presentation; (b) Final Report (hard copy); (c) Knowledge Transfer Session(s)		
4.0	Project Management	PM, supported by Technical Team	45 days
	Kick-off Meeting to discuss Scope of Work (with feedback session for the City IT Security Team to identify specific network locations and systems to include within scope). Project oversight, issue management, report writing/editing and production, presentation development and delivery. Draft Audit of Findings to be circulated, and a review of draft findings conducted prior to submission of final report(s), with feedback and inputs incorporated by JLGOV.		
	Deliverables: (a) Draft and On-going Revised Project Management Plan (PMP); (b) Weekly Activity Reports; (c) Final Project Report (close-out)		

Schedule

Assuming timely award, JLGOV will start no later than May 1, 2014 with the kick-off meeting at the City of Portsmouth IT Department, with a planned completion by June 30, 2014.

Exhibit: Timeline of Project Activities



Cost

City of Portsmouth City of Portsmouth Network Audit and Vulnerability Assessment								
Base Period - 05/01/2014 to 6/30/2014								
Position/Labor Category	**Staff Person**	**Rate**	**WBS 1**	**WBS 2**	**WBS 3**	**WBS 4**	**Total Hours**	**Cost**
1. Project Manager/Tech Writer (On-site)	Hallet Chapman							
2. Technical Lead/Senior Security Engineer	Fred Hopewell							
3. Senior Security Engineer	Gregory Perry							

Quality Control

JLGOV's organization is responsive to its customers by featuring short, direct lines of communication and control to senior managers. Project Managers are responsible for the contract's cost, schedule, performance management, growth, and customer satisfaction. The JLGOV structure provides the assigned Project Manager with immediate access to additional corporate resources to support contract performance if needed. This structure allows Project Managers and staff sufficient time to focus on providing the highest quality services and solutions to our clients. Additionally, customers are invited to contact any member of executive management including the President/CEO who has an "Open Door" policy.

Customer satisfaction is critical to the success of any business. We have instituted a customer satisfaction program that involves the client in determining performance and measurement metrics. We interview our clients to establish quantitative and qualitative satisfaction data for overall performance.

Interview data is collected, analyzed, and evaluated to develop an individualized customer satisfaction plan. Our goal is to continue to exceed expectations and provide solutions that meet our customer's goals and program objectives. JLGOV's Quality Control Plan (QCP) details our efforts to manage quality and maintain customer satisfaction while supporting the City of Portsmouth's network security assessment. Our QCP approach incorporates ITIL industry standards and ISO 9001:2008 best practices and is designed to facilitate the successful completion of all required tasks and associated outputs and deliverables outlined in the RFP. Our QCP is a prevention-based approach designed to make the most efficient use of resources while driving continuous improvements within our team and productive collaborations with the client. JLGOV's QCP ensures we fully comply with the RFP requirements during the execution of this project and serves as the mechanism for quality control.

Our quality control standards include review processes, techniques, and tools that we will leverage to ensure quality is maintained for all RFP requirements throughout the life of the contract. The table below identifies and describes the purpose of each section of the Quality Control Plan, the draft of which is to be presented at the kick-off meeting.

Exhibit: Quality Control Framework

Title	Purpose
Framework and Objectives	Define, in detail, what the City of Portsmouth IT Department and JLGOV's QCP aims to accomplish.
Quality Planning/Baseline	Outlines the quality standards applicable to the RFP and determines how best to meet those standards. Defines the key tools and processes that drive quality and employs problem prevention techniques.
Quality Assurance	Outlines the processes JLGOV has in place to ensure quality. This includes utilizing checklists, surveys and inspection points to evaluate the current state of quality for a given project.
Quality Control	Describes how JLGOV will utilize the project team to manage quality. Defines our quality metrics that will be used to evaluate the quality of our team's work.
Quality Team	Defines the roles and responsibilities of those personnel responsible for performing quality control and maintaining customer satisfaction.
Continuous Improvement	Outlines how we strive to improve quality by gathering continuous feedback to maintain positive consumer satisfaction. We further define how we will record quality issues and implement corrective action when necessary.
Reporting	Outlines our quality management and quality assurance problem reporting plans. Defines how JLGOV will incorporate feedback mechanisms for evaluating service, staffing, and other risk factors to provide rapid corrections and eliminate problems.

JLGV will support the City of Portsmouth network vulnerability assessment project with a quality baseline formed from several core components. Our proven CMMI Level 3-compliant methodologies, processes, techniques, templates, and tools are used to support our tasks and specific deliverables. Our team has in depth experience; we have repeatable methods and

reusable techniques, templates, and tools to guide our work. At the onset of each project, JLGOV will customize our methods, techniques, templates, and tools to meet the City's specific requirements. Customizations include adapting specific standards, nomenclature and other elements to meet the client's needs. We distribute our customized methods, tools and templates across our team and communicate how each is to be used. This practice allows our team to promote a consistent quality approach in our delivery. Our key tools and processes are listed in the following exhibit.

Exhibit: Performance Measures

ID	Performance Objective	Required Outcome	Acceptable Quality Level	Method of Surveillance	Frequency	Incentive/Disincentives
1	The team will adhere to all requirements in accordance with the RFP.	The team is in compliance throughout the period of performance	95%	CO/COR periodic Inspection	Ongoing	Incentives: Favorable contractor performance evaluation, Disincentive: A Contract Discrepancy Report (CDR) may be issued on the first instance of failure to provide the acceptable level Two or more issued CDRs may result in reduction of the monthly invoice of 5% and an unfavorable contractor performance evaluation
2	Weekly Activity Report	Describes activities and progress to date	Reports the task status of the previous week. Includes accomplishments/ tasks completed, tasks planned/in-progress, and outstanding issues.	CO/COR Inspection	Monthly	Incentives: Favorable contractor performance evaluation, Disincentive: A Contract Discrepancy Report (CDR) may be issued on the first instance of failure to provide the acceptable level Two or more issued CDRs may result in reduction of the monthly invoice of 2% and an unfavorable contractor performance evaluation

ID	Performance Objective	Required Outcome	Acceptable Quality Level	Method of Surveillance	Frequency	Incentive/Disincentives
3	Project Management Approach	Defines the risk management, issue management, quality management, and performance reporting processes.	Addresses the processes (such as risk management, issue management, quality management, Performance Reporting, etc.) that facilitate execution of project management effort.	CO/COR Inspection	At outset of tasking	Incentives: Favorable contractor performance evaluation. Disincentive: A Contract Discrepancy Report (CDR) may be issued on the first instance of failure to provide the acceptable level Two or more issued CDRs may result in reduction of the monthly invoice of 2% and an unfavorable contractor performance evaluation
n..	Others TBD at kick-off	TBD at kick-off	TBD at kick-off	TBD at kick-off	As required	TBD at kick-off

Our quality baseline is further comprised of metrics that will be used to evaluate the quality of our work. These metrics include the following:

- Timeliness – Each deliverable is provided at the agreed upon date and time.
- Completeness – Each deliverable conforms to the specified requirements for content.
- Accuracy – Each deliverable provides information that is accurate, reliable and verifiable.
- Clarity – Each deliverable is clear, concise and logical in its presentation of information.
- Will acknowledge initial deliverables and complete within two business days.
- Professionalism – Will interact with all client personnel with dignity and respect.
- Customer satisfaction – There are no unresolved complaints about JLGOV
- Responsiveness – Will acknowledge and respond to written feedback by key stakeholders

JLGOV's quality control and self-inspection responsibilities are managed by the company's project leaders and facilitated by an independent quality reviewer from within our firm. The quality reviewer is a designated subject matter expert from JLGOV. The quality assurance reviewer ensures that our team has the required policies, processes and tools in place to meet both our own and the client's quality standards.

At kick-off of the project, JLGOV team members and City of Portsmouth personnel will meet to identify overall project and specific IT security assessment services goals, and project deliverables for review throughout the project life cycle. Selection of the deliverables will be based on criteria established at the outset. Criteria for evaluating deliverables can include: project importance, SLAs, cost, schedule, impact, and complexity. By using these criteria in the quality planning phase, we ensure that the quality control process is at a level commensurate with the project attributes.

Staffing Plan

JLGOV's primary staffing objective is to maintain continuity of operations for security assessment activities by ensuring the contract is properly staffed with technically skilled, highly qualified and certified professionals. JLGOV's staffing methodology has proven successful in fulfilling RFP requirements of similar scope and size and is built on several objectives: Maintain a pool of qualified candidates to address attrition and new or temporary staffing requirements quickly.

Retain all assigned personnel on a long term basis via a competitive compensation plan, job satisfaction, professional development and a corporate commitment to a work life balance. All combined provides a stable workforce, maintains project performance continuity, and reduces recruiting and training costs.

Our team has successfully recruited for new contract startups and for backfilling vacated positions due to performance issues, new customer requirements or normal attrition. Strategic recruiting as it is referred to within our team, is necessary due to the unique personnel qualifications required by our customers. As such, JLGOV's security team specialized recruiting group includes dedicated recruiters, who are intimately knowledgeable of the technical requirements of our customers within environments similar to those of the City of Portsmouth.

During our proposal development, JLGOV undertook an extensive recruiting effort to identify resources from our combined employee base as well as creating a resume pool of potential candidates. Therefore, in the event that any portion of the team does not transition, our pool of alternate personnel is qualified and available to support the client upon award.

Scope. This Staffing Plan identifies the process and procedures used to manage staff throughout the project's life. The plan describes the planning and acquisition of both state staff and consulting staff, describes the responsibilities assigned to each staff, and discusses transition of staff to other assignments.

External References. PMBOK Guide, 3rd Edition, Section 9 - Project Human Resource Management and Government Extension to the PMBOK Guide 3rd Edition, Section 9.

Staff Maintenance. The staffing plan will be reviewed regularly and updated as needed, as a project proceeds through each phase of the system development life cycle. Lessons learned as a result of continuing staff management efforts will be captured at the end of each project phase and used to improve project and our standards. If the document is written in an older format, the document should be revised into the latest processes and procedures.

At JLGOV, we have a set of CMMI Level 3-compliant processes in place for the staff management process. For this project, applicable processes consists of the following: Staff Planning, Staff Acquisition, Staff Training, Staff Tracking, and Staff Transition.

Exhibit: Staffing Matrix

Position	Role	Responsibility	LOE
Project Manager	The Project Manager heads a team conducting security assessment/audit activities in support of this project and mission execution.	Duties for this project include monitoring tasks, processes and deliverables. He is knowledgeable and practiced in all aspects of information technology security, III, IV&V, Certification and Accreditation, and system life cycle development processes.	100%
Security Assessment - Team Lead/Senior Engineer	The Lead/Senior Security Engineer performs technical task planning and supports the Project Manager in the execution and control of the project.	Interacts directly with client personnel providing an on-site presence to ensure delivery of quality products. He performs security assessments, mans the software tools, and understands full-lifecycle (i.e., Concept to Deployment) analysis to ensure the logical and systematic implementation of activities to meet of customer requirements I a process-centric model that acknowledge technical constraints. Requires cross-team coordination. Prepares, evaluates and implements corrective action plans based on quality metrics.	100%
Security Assessment /Tester - Senior Engineer	Works with the Technical Lead and other team members on various aspects of supporting security vulnerability testing.	The Security Analyst is responsible for the verification of complex hardware and software processing systems for all phases of penetration testing and other activities. Responsibilities include planning and sequence development; vulnerability plan preparation and implementation; verification requirements development; test procedure development; tool integration; tool installation at field sites; test readiness reviews; test conduct at field sites; test report development; and discrepancy reporting and resolution. Requires cross-team coordination. Prepares, evaluates and implements corrective action plans based on quality metrics.	100%